ICS 35.040
L 80
备案号:44636—2014

GM

中华人民共和国密码行业标准

GM/T 0035.1—2014

射频识别系统密码应用技术要求
第1部分:密码安全保护框架及安全级别

Specifications of cryptographic application for RFID systems—
Part 1: Cryptographic protection framework and security levels

2014-02-13 发布　　2014-02-13 实施

国家密码管理局　　发布

GM/T 0035.1—2014

中 华 人 民 共 和 国 密 码
行 业 标 准
射频识别系统密码应用技术要求
第 1 部分:密码安全保护框架及安全级别
GM/T 0035.1—2014
*
中 国 标 准 出 版 社 出 版 发 行
北京市朝阳区和平里西街甲 2 号(100029)
北京市西城区三里河北街 16 号(100045)
网址 www.spc.net.cn
总编室:(010)64275323 发行中心:(010)51780235
读者服务部:(010)68523946
中国标准出版社秦皇岛印刷厂印刷
各地新华书店经销
*
开本 880×1230 1/16 印张 1.5 字数 38 千字
2014 年 5 月第一版 2014 年 5 月第一次印刷
*
书号:155066·2-27016 定价 27.00 元

如有印装差错 由本社发行中心调换
版权专有 侵权必究
举报电话:(010)68510107

GM/T 0035.1-2014

目　　次

前 言 …… Ⅲ
1　范围 …… 1
2　规范性引用文件 …… 1
3　术语和定义 …… 1
4　符号和缩略语 …… 4
5　射频识别系统安全 …… 5
5.1　射频识别系统密码安全保护框架 …… 5
5.2　射频识别系统密码应用技术标准框架 …… 5
5.3　密码安全保护框架及安全级别 …… 6
5.4　电子标签安全 …… 6
5.5　读写器安全 …… 6
5.6　电子标签与读写器通信安全 …… 6
5.7　密钥管理 …… 6
6　射频识别系统安全级别划分及技术要求 …… 6
6.1　级别划分 …… 6
6.2　各级别密码安全技术要求 …… 7
7　密码算法配用 …… 9
附录 A（资料性附录）　电子标签防伪应用密码安全解决方案 …… 10
A.1　方案概述 …… 10
A.2　电子标签芯片密码安全技术及其实现 …… 11
A.3　电子标签读写器密码安全技术及安全实现 …… 12
A.4　电子标签与读写器通信安全技术 …… 14
A.5　密码算法及密钥管理 …… 16

前　　言

GM/T 0035《射频识别系统密码应用技术要求》分为五个部分：

——第 1 部分：密码安全保护框架及安全级别；

——第 2 部分：电子标签芯片密码应用技术要求；

——第 3 部分：读写器密码应用技术要求；

——第 4 部分：电子标签与读写器通信密码应用技术要求；

——第 5 部分：密钥管理技术要求。

本部分为 GM/T 0035 的第 1 部分。

本部分按照 GB/T 1.1—2009 给出的规则起草。

本部分由密码行业标准化技术委员会提出并归口。

本部分起草单位：上海华申智能卡应用系统有限公司、复旦大学、上海华虹集成电路有限责任公司、北京中电华大电子设计有限责任公司、上海复旦微电子集团股份有限公司、兴唐通信科技有限公司、北京同方微电子有限公司、航天信息股份有限公司、北京华大智宝电子系统有限公司。

本部分主要起草人：顾震、董浩然、王俊宇、谢文录、王云松、梁少峰、俞军、吴行军、王俊峰、周建锁、徐树民、陈跃、柳逊、王会波。

射频识别系统密码应用技术要求
第1部分:密码安全保护框架及安全级别

1 范围

GM/T 0035的本部分规定了射频识别系统密码安全保护框架及安全级别,以及与GM/T 0035.2—2014、GM/T 0035.3—2014、GM/T 0035.4—2014和GM/T 0035.5—2014之间的相互关系。附录A给出了一个射频识别系统密码安全方案示例。

本部分适用于射频识别系统密码安全的设计、实现与应用。

2 规范性引用文件

下列文件对于本文件的应用是必不可少的。凡是注日期的引用文件,仅注日期的版本适用于本文件。凡是不注日期的引用文件,其最新版本(包括所有的修改单)适用于本文件。

GM/T 0035.2—2014 射频识别系统密码应用技术要求 第2部分:电子标签芯片密码应用技术要求

GM/T 0035.3—2014 射频识别系统密码应用技术要求 第3部分:读写器密码应用技术要求

GM/T 0035.4—2014 射频识别系统密码应用技术要求 第4部分:电子标签与读写器通信密码应用技术要求

GM/T 0035.5—2014 射频识别系统密码应用技术要求 第5部分:密钥管理技术要求

3 术语和定义

下列术语和定义适用于本文件。

3.1

安全存取模块 secure access module

嵌入在读写器内的密码模块,为读写器提供安全服务。

3.2

电子标签 RFID tag

一种用于射频识别,载有与预期应用相关的电子识别信息的载体,每个标签具有唯一的电子编码。通常由耦合元件及芯片组成,包括非接触CPU卡和非接触存储卡。

3.3

读写器 reader

与电子标签进行数据通信并对标签进行读、写操作的设备。

3.4

对称密码算法 symmetric cryptographic algorithm

加解密使用相同密钥的密码算法。

3.5

非对称密码算法/公钥密码算法 asymmetric cryptographic algorithm/public key cryptographic algorithm

加解密使用不同密钥的密码算法。其中一个密钥(公钥)可以公开,另一个密钥(私钥)必须保密,且

由公钥求解私钥是计算不可行的。

3.6

分散密钥　derived key

由根密钥和非保密可变数据生成的对称密钥。

3.7

根密钥　derivation key

用来生成分散密钥的密钥。

3.8

公钥　public key

非对称密码算法中可以公开的密钥。

3.9

公钥证书　public key certificate

一种数字证书，由认证机构签名的包含公开密钥拥有者信息、公开密钥、签发者信息、有效期以及一些扩展信息的数字文件。

3.10

会话密钥　session key

在一次会话中使用的数据加密密钥。

3.11

机密性　confidentiality

保证信息不被泄露给非授权的个人、进程等实体的性质。

3.12

加密　encipherment/encryption

对数据进行密码变换以产生密文的过程。

3.13

鉴别　authentication

确认一个实体所声称的身份或信息的真实性。

3.14

解密　decipherment/decryption

加密过程对应的逆过程。

3.15

抗抵赖　non-repudiation

也称不可否认，证明一个操作或事件已经发生且无法否认的机制。

3.16

客体　object

信息的载体。

3.17

密码模块　cryptographic module

实现密码运算功能的，相对独立的软件、硬件、固件或其组合。

3.18

密码算法　cryptographic algorithm

描述密码处理过程的运算规则。

3.19

密码协议　cryptography protocol

两个或两个以上参与者使用密码算法，按照约定的规则，为达到某种特定目的而采取的一系列步骤。

3.20

密码杂凑函数　cryptographic hash function

又称密码散列函数或密码哈希函数，将一个任意长的比特串映射到一个固定长的比特串的函数，且满足下列特性：

a)　为一个给定的输出找出能映射到该输出的一个输入是计算上困难的；

b)　为一个给定的输入找出能映射到同一个输出的另一个输入是计算上困难的；

c)　要发现不同的输入映射到同一输出是计算上困难的。

3.21

密钥管理　key management

根据安全策略，对密钥的产生、分发、存储、更新、归档、撤销、备份、恢复和销毁等密钥全生命周期的管理。

3.22

密钥协商　key agreement

两个或多个实体通过相互传送一些消息来共同建立一个共享的秘密密钥的协议，且各个实体无法预先确定这个秘密密钥的值。

3.23

射频识别　radio frequency identification

利用射频信号通过空间耦合(交变磁场或电磁场)实现信息的无接触传递，并通过所传递的信息达到识别目的。

3.24

审计　audit

对信息系统记录与活动进行的独立观察和考核。

3.25

数据完整性　data integrity

数据没有遭受以非授权方式所作的篡改或破坏的性质。

3.26

数字签名　digital signature

签名者使用私钥对待签名数据的杂凑值做密码运算得到的结果，该结果只能用签名者的公钥进行验证，用于确认待签名数据的完整性、签名者身份的真实性和签名行为的抗抵赖性。

3.27

私钥　private key

非对称密码算法中只能由拥有者使用的不公开密钥。

3.28

SM1 算法　SM1 algorithm

一种分组密码算法，分组长度为 128 比特，密钥长度为 128 比特。

3.29

SM2 算法　SM2 algorithm

一种椭圆曲线公钥密码算法，其密钥长度为 256 比特。

3.30

SM3 算法　SM3 algorithm

一种密码杂凑算法，其输出为 256 比特。

3.31

SM4 算法　SM4 algorithm

一种分组密码算法，分组长度为 128 比特，密钥长度为 128 比特。

3.32

SM7 算法　SM7 algorithm

一种分组密码算法，分组长度为 64 比特，密钥长度为 128 比特。

3.33

SSL 协议　secure socket layer protocol

一种传输层安全协议，用于构建客户端和服务端之间的安全通道。

3.34

随机数　random number

一种数据序列，其产生不可预测，其序列没有周期性。

3.35

消息鉴别码　message authentication code

又称消息认证码，是消息鉴别算法的输出。

3.36

唯一标识符　unique identifier

由电子标签芯片制造商固化在电子标签芯片内的唯一标识符，包含芯片生产序列号、经注册的厂商代码等唯一性信息。

3.37

主体　subject

引起信息在客体之间流动的人、进程或设备等。

4　符号和缩略语

4.1　符号

下列符号适用于本文件。

‖：数据连接符，将信息串联，表示左侧和右侧数据拼接在一起形成一个新的数据

Enc(X,K)：加密运算符，用密钥 K 对 X 进行加密运算

Dec(X,K)：解密运算符，用密钥 K 对 X 进行解密运算

⊕：比特异或

4.2　缩略语

下列缩略语适用于本文件。

CBC-MAC：采用对称算法密码块链接模式生成的消息鉴别码(Cipher Block Chaining Message Authentication Code)

CRC：循环冗余校验(Cyclic Redundancy Check)

HMAC：采用密码杂凑函数生成的消息鉴别码(Hash Message Authentication Code)

MAC：消息鉴别码(Message Authentication Code)

RFID：射频识别(Radio Frequency IDentification)

RNG:随机数发生器(Random Number Generator)
SAM:安全存取模块(Secure Access Module)
UID:唯一标识符(Unique IDentifier)

5 射频识别系统安全

5.1 射频识别系统密码安全保护框架

射频识别系统密码安全保护框架由电子标签安全、电子标签与读写器通信安全、读写器安全、读写器与中间件通信安全、中间件安全、中间件与信息处理系统通信安全、信息处理系统安全、密钥管理等构成,其相互关系如图1所示。

GM/T 0035规定了其中的电子标签安全、电子标签与读写器通信安全、读写器安全和密钥管理。读写器与中间件通信安全、中间件安全、中间件与信息处理系统通信安全、信息处理系统安全属于通用的网络安全范畴,不在GM/T 0035规定的范围之内。

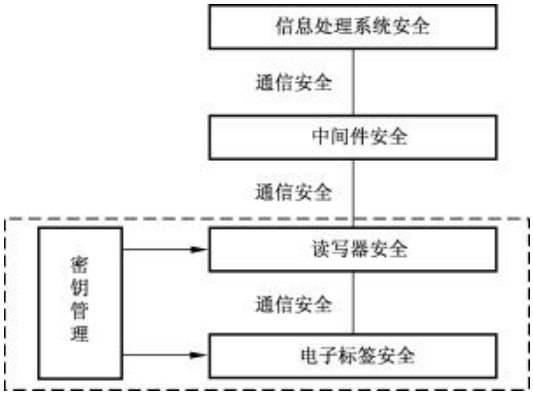

图 1 射频识别系统密码安全保护框架

5.2 射频识别系统密码应用技术标准框架

射频识别系统密码应用技术标准框架见图2。

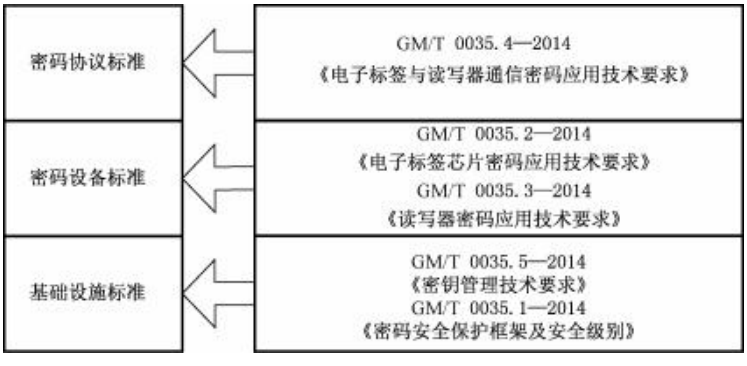

图 2 射频识别系统密码应用技术标准框架

其中,电子标签芯片与读写器中的安全存取模块是射频识别系统中的密码设备,GM/T 0035.2和GM/T 0035.3为密码设备标准;GM/T 0035.4为密码协议标准;本部分和GM/T 0035.5为基础设施标准。

5.3 密码安全保护框架及安全级别

规定了射频识别系统安全保护框架、安全级别划分、各级别密码安全技术要求和密码算法配用。

5.4 电子标签安全

电子标签的安全要素包括:存储信息和传输信息的机密性、存储信息和传输信息的完整性、抗抵赖、身份鉴别、访问控制、审计记录、密码配置。

相关技术要求见 GM/T 0035.2—2014。

5.5 读写器安全

读写器的安全要素包括:存储信息和传输信息的机密性、存储信息和传输信息的完整性、抗抵赖、身份鉴别、访问控制、审计记录、密码配置。

相关技术要求见 GM/T 0035.3—2014。

5.6 电子标签与读写器通信安全

电子标签与读写器通信安全要素包括:传输信息的机密性、传输信息的完整性、身份鉴别。其中身份鉴别包括唯一标识符鉴别、电子标签对读写器的挑战响应鉴别、读写器对电子标签的挑战响应鉴别、电子标签与读写器之间的双向挑战响应鉴别。

相关技术要求见 GM/T 0035.4—2014。

5.7 密钥管理

规定了射频识别系统在采用密码机制时电子标签、读写器及其通信相关的密钥管理要求。

相关技术要求见 GM/T 0035.5—2014。

6 射频识别系统安全级别划分及技术要求

6.1 级别划分

根据密码安全技术要求的不同将射频识别系统划分为四个级别,在各个级别中规定了射频识别系统应支持的最低安全防范措施,其安全强度逐级提高。用户可以根据不同的安全需求进行级别选择。

第一级适用于一些对安全性要求不高的应用,应采用身份鉴别安全机制;

第二级适用于一些对安全性具有一定要求的应用,应采用身份鉴别和访问控制安全机制;

第三级适用于一些对安全性具有较高要求的应用,应采用机密性、完整性、抗抵赖、身份鉴别和访问控制安全机制;

第四级适用于一些对安全性具有很高要求的应用,应采用机密性、完整性、抗抵赖、身份鉴别、访问控制和审计等安全机制。

以下内容在密码安全级别划分中不予考虑:

——行政管理的安全措施;

——物理方面的安全措施;

——密码算法的质量评价。

6.2 各级别密码安全技术要求

6.2.1 第一级

6.2.1.1 身份鉴别

应采用唯一标识符鉴别技术实现对电子标签的唯一性身份鉴别，具体要求见GM/T 0035.2—2014、GM/T 0035.3—2014 和 GM/T 0035.4—2014。

6.2.1.2 密码配置

6.2.1.2.1 密码算法

射频识别系统中配置的密码算法应为符合国家密码管理主管部门相关要求的对称密码算法。

6.2.1.2.2 密钥管理

遵照国家密码管理主管部门颁布的有关规范和技术标准，实行自主管理。密钥管理应包括密钥生成、密钥注入、密钥存储、密钥分散与密钥使用等，具体要求见 GM/T 0035.5—2014。

6.2.2 第二级

6.2.2.1 身份鉴别

应支持读写器对电子标签的挑战响应鉴别，以确定电子标签身份的真实性。

6.2.2.2 访问控制

应支持访问控制机制，使其能采用密码验证机制实现系统中授权用户对客体访问权限的定义和控制，阻止非授权用户对敏感信息的访问。

6.2.2.3 密码配置

6.2.2.3.1 密码算法

同 6.2.1.2.1 要求。

6.2.2.3.2 密钥管理

同 6.2.1.2.2 要求。

6.2.3 第三级

6.2.3.1 机密性

应支持存储信息机密性保护功能，使其能对存储在电子标签内的敏感信息进行加密保护，确保非授权读写器不能获得或修改该信息。

应支持读写器与电子标签之间传输信息机密性保护功能，使其能对读写器与电子标签之间的通信信息进行加密保护，确保信息在传输过程中不被泄漏或窃取。

6.2.3.2 完整性

应支持存储信息完整性保护，使其能采用密码技术对存储在射频识别系统内的敏感信息进行校验，以发现信息被篡改、删除或插入等情况。

应支持传输信息完整性保护，使其能采用密码技术对电子标签和读写器之间传输的敏感信息进行校验，以发现信息被篡改、删除或插入等情况。

6.2.3.3 抗抵赖

应支持抗电子标签原发抵赖功能，使其能确保电子标签信息原发者不能成功地否认曾经生成过该信息，接收电子标签信息的主体能获得证明电子标签信息原发者的证据，而且该证据可由该主体或第三方验证。

应支持抗读写器抵赖功能，使其能确保读写器不能成功地否认曾经生成过该信息，接收读写器信息的主体能获得证明读写器信息原发的证据，而且该证据可由该主体或第三方等其他主体验证。

6.2.3.4 身份鉴别

应支持读写器对电子标签的挑战响应鉴别，同 6.2.1.1 要求。

应支持电子标签对读写器的挑战响应鉴别，以确定读写器身份的真实性。

6.2.3.5 访问控制

同 6.2.2.2 要求。

6.2.3.6 密码配置

6.2.3.6.1 密码算法

射频识别系统中配置的密码算法应为符合国家密码管理主管部门相关要求的对称密码算法、非对称密码算法和密码杂凑函数。

6.2.3.6.2 密钥管理

同 6.2.1.2.2 要求。

6.2.4 第四级

6.2.4.1 机密性

同 6.2.3.1 要求。

6.2.4.2 完整性

同 6.2.3.2 要求。

6.2.4.3 抗抵赖

应支持抗电子标签原发抵赖功能，同 6.2.3.3 要求。

应支持抗读写器抵赖功能，同 6.2.3.3 要求。

应支持抗电子标签抵赖功能，即电子标签能对其生成的信息产生数字签名，确保电子标签不能成功地否认曾经生成过该信息，接收电子标签信息的主体能获得证明电子标签信息原发的证据，而且该证据可由该主体或第三方验证。

6.2.4.4 身份鉴别

同 6.2.3.4 要求。

6.2.4.5 访问控制

同 6.2.2.2 要求。

6.2.4.6 审计

电子标签、读写器都应具备审计功能，使其能对涉及应用系统安全的数据及相关操作（潜在的安全侵害）情况进行记录，内容至少包括使用主体、使用时间、执行的操作等，并采取有效措施保证记录信息的安全，以便追溯并评估所储存数据和操作的安全性。

6.2.4.7 密码配置

6.2.4.7.1 密码算法

同 6.2.3.6.1 要求。

6.2.4.7.2 密钥管理

同 6.2.1.2.2 要求。

7 密码算法配用

在射频识别系统中应选择国家密码管理主管部门认可的密码算法。

a） 对称密码算法

用于身份鉴别、访问控制、机密性保护、完整性保护、密钥协商和密钥分散。

b） 非对称密码算法

用于抗抵赖、身份鉴别、机密性保护、完整性保护、密钥协商和密钥交换。

c） 密码杂凑函数

用于产生数据摘要信息，进行完整性校验。

附　录　A
（资料性附录）
电子标签防伪应用密码安全解决方案

A.1　方案概述

本附录给出了一个符合 RFID 应用系统安全级别的第二级安全要求的电子标签防伪应用安全解决方案，本方案涉及的内容对包括电子标签、读写器、中间件信息安全在内的防伪应用系统。

电子标签应用系统面临的安全威胁有：非法访问、跟踪、窃听、伪造、物理攻击、恶意破坏等方面。使用密码技术实现防伪安全应用系统的数据完整性、合法性验证，数据访问权限控制，标签通信信道安全，并根据应用系统各组成列出部分的安全需求及密码技术解决措施，提炼出整个应用系统的密码安全解决方案，以保证整个应用系统的信息安全。

图 A.1 是一个典型电子标签防伪应用系统安全架构图。

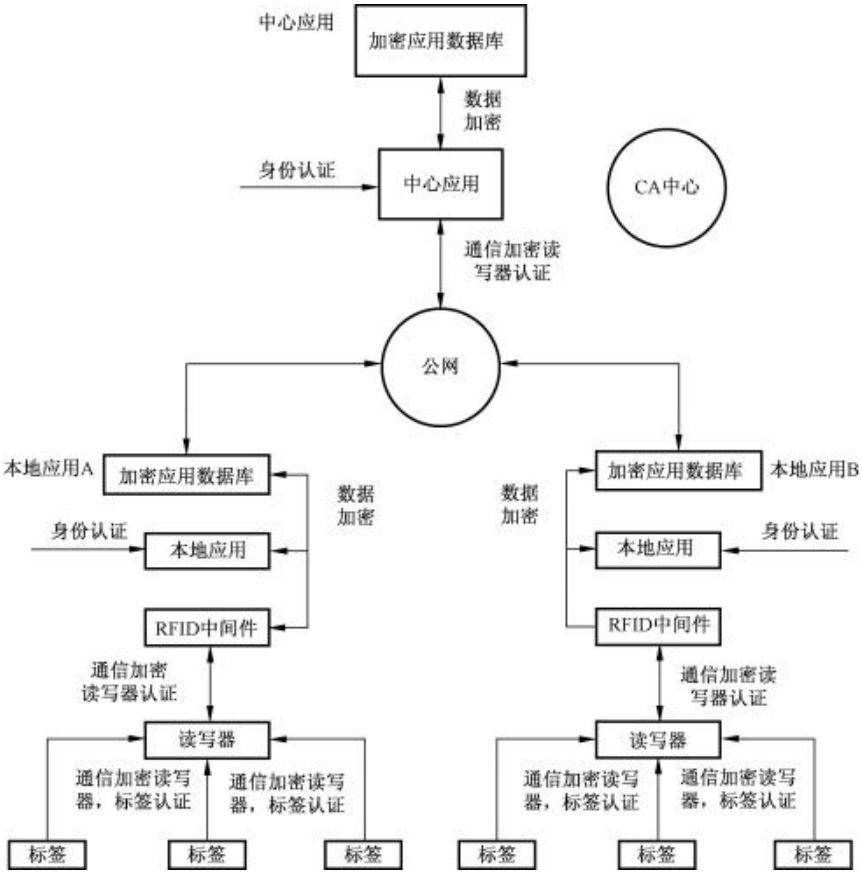

图 A.1　系统安全架构图

防伪应用系统安全解决方案涉及电子标签芯片密码安全技术及其实现、读写器密码安全技术及其实现、中间件密码安全技术、电子标签与读写器通信安全技术和读写器与中间件通信安全，其密码技术的安全体系如图 A.2 所示。

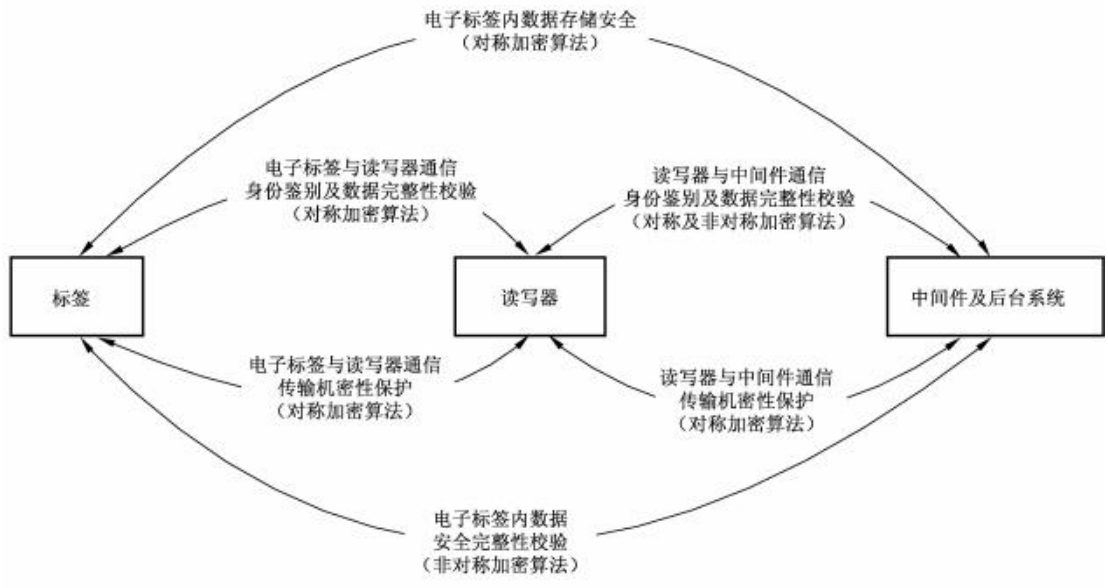

图 A.2　密码防伪应用安全体系

A.2　电子标签芯片密码安全技术及其实现

A.2.1　电子标签安全需求

防伪用电子标签主要面临的安全威胁有：对标签的非法访问、伪造、数据篡改、物理攻击、恶意破坏等。其对应的安全需求有：标签的身份鉴别、信息存储安全、访问控制安全、标签管理安全等。其中标签管理安全不涉及密码技术，本方案不作规定。

A.2.2　电子标签身份鉴别

采用对称密码算法 SM7 对标签进行身份鉴别，从而保证标签身份的合法性。身份鉴别采用的密钥通过电子标签 UID 对根密钥分散获得。

具体身份鉴别过程见 GM/T 0035.4—2014。

A.2.3　电子标签信息存储安全

对存储在标签内的敏感信息采用对称密码算法 SM1/SM4 加密，并用杂凑算法 SM3 生成摘要信息实现对存储信息的完整性校验，以保证标签内存储的敏感信息在面临数据篡改、物理攻击等安全威胁时，攻击者得不到明文数据，同时在数据被篡改后也能被及时发现，从而保证敏感信息的存储安全。

信息加密采用的密钥可通过 UID 对信息加密根密钥分散获得，解密方通过授权获得此密钥。具体过程参见 A.5.3。

A.2.4　电子标签访问控制安全

对不同的信息通过不同的密钥设置访问控制权限，以保证电子标签及其存储信息面临非法访问、数据篡改、恶意破坏等威胁时，攻击者不能进行相关读、写、修改、创建、删除等操作，从而保证敏感信息及电子标签的安全。

具体密钥设置参见 A.5.2。

A.2.5 安全实现

采用将 CA 认证和数字签名与电子标签相结合的技术，实现电子标签数据加密和信息认证。

在电子标签芯片初始化处理过程中，系统将完成基本信息和合法身份鉴别信息向芯片内的写入。

A.2.5.1 随机数发生器

标签内具有随机数发生器(RNG)，随机数的产生不依赖于通信电磁场、链路速率和存储在标签内的数据(包括 UID、CRC 等)。标签采用 RNG 生成的随机数(长度由链路加密的总长度决定)，完成一次链路加密后，随机数应予以丢弃，下一次链路通信必须生成新的随机数。

A.2.5.2 电子标签身份信息数据写入

将电子标签的 UID 等特征信息串联(如 UID‖特征信息 1‖特征信息 2)，通过杂凑算法 SM3 计算生成特征码，即“消息摘要”，采用信息写入者的私钥对“消息摘要”进行数字签名，数字签名可以确定电子标签信息的实际身份和使用许可的真实性、合法性。

A.2.5.3 标签信息数据写入

读写器对电子标签操作前通过与电子标签之间的双向身份鉴别，并获得相应应用分区的操作密钥，将基本信息加密后写入标签的基本信息应用分区，通过杂凑算法 SM3 将该基本特征信息与电子标签芯片 UID 码进行运算生成该电子标签的消息摘要，将消息摘要用信息写入者的私钥进行数字签名并写入标签签名区。

A.2.5.4 访问权限

数据存储区中数据块的访问权限由密钥权限区中的密钥决定，对应数据块的权限被设置以后，加密链路也同时生效。

密钥权限区本身没有权限控制，当主密钥(MASTER KEY)被设置了之后，访问密钥权限区的加密链路也同时生效，对密钥区的访问以只写(不能读)方式进行。

A.2.5.5 标签数据解密及签名验证

读写器对电子标签操作前通过双向鉴别获得相应应用分区的操作密钥，访问标签基本信息区，读取标签芯片序列号以及标签基本特征信息，通过杂凑算法 SM3 生成该标签的消息摘要；同时访问标签的数字签名区，读取标签身份数字签名信息，通过信息写入者公钥验证数字签名。

A.2.5.6 KILL 指令(可选)

当主密钥被设置后，KILL 指令生效且必须以链路加密的方式发送指令。当读写器发送了有效的 KILL 指令后，标签将不应答来自于读写器的任何请求指令。

A.3 电子标签读写器密码安全技术及安全实现

A.3.1 读写器安全需求

防伪用电子标签读写器主要面对安全威胁有：对读写器的非法访问、伪造、数据篡改、物理攻击、恶意破坏等，对应的，其安全需求有：读写器的身份鉴别、信息存储安全、访问控制安全、读写器管理安全等部分组成。其中读写器管理安全不涉及密码技术，本方案不作规定。

A.3.2 读写器身份鉴别

防伪用读写器与标签间的双向身份鉴别采用对称密码算法 SM7 加密的三重身份鉴别机制，与中间件间的双向身份鉴别采用基于 PKI 的 SSL 协议身份鉴别机制，以保证读写器在面临伪造等安全威胁时，攻击者无法通过身份鉴别，从而保证读写器身份的合法性。

具体密钥设置参见 A.5.2。

A.3.3 读写器信息存储安全

对将要存储在读写器内的敏感信息采用对称密码算法 SM1/SM4 加密，并用杂凑算法 SM3 生成摘要信息进行存储数据完整性校验，以保证读写器内存储的敏感信息在面临数据篡改、物理攻击等安全威胁时，攻击者得不到明文数据，同时在数据被篡改后也能被及时发现，从而保证敏感信息存储安全。

具体密钥设置参见 A.5.3。

A.3.4 读写器访问控制安全

对不同信息通过不同的密钥设置访问控制权限，使具有不同密钥的中间件及应用系统具有对读写器不同信息读取区域及不同的相关读、写、修改、创建、删除等操作权限，以保证读写器及其存储信息在面临非法访问、数据篡改、恶意破坏等安全威胁时，攻击者不能进行相关读、写、修改、创建、删除等操作，从而保证敏感信息安全。

具体密钥设置参见 A.5.2。

A.3.5 读写器抗抵赖

读写器生成信息时加入代表其身份的数字签名，确保读写器不能否认曾经生成过该信息，接收信息的主体也能获得信息原发的证据，而且该证据可被该主体或第三方主体验证。

具体方法参见 A.5.4。

A.3.6 读写器审计

对涉及应用系统安全的数据及相关操作（潜在的安全侵害）情况进行记录，内容至少包括：使用主体、使用时间、执行的操作等，追溯并评估所记录数据和操作的安全性。并采取有效措施保证记录的安全。

A.3.7 安全实现

读写器安全实现从基本结构、安全存取模块和访问流程三个方面来阐述。

A.3.7.1 基本结构

读写器的基本结构包括：通信模块、射频模块、安全存取模块和微处理器。基本结构如图 A.3 所示。

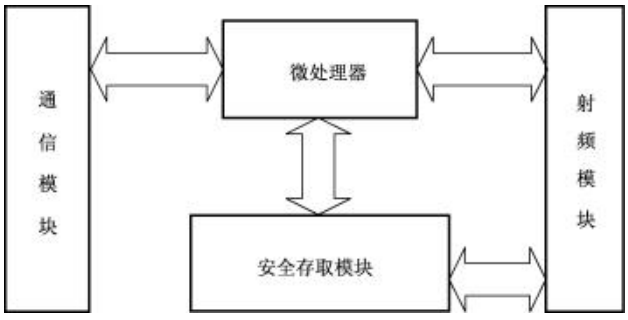

图 A.3　读写器基本结构图

通信模块负责读写器与系统之间的物理层接口；射频模块负责读写器与标签之间的物理层接口；安全存取模块负责读写器与标签之间通信链路的加/解密和指令的编/解码；微处理器负责对来自于标签或系统的指令解析、处理和数据转发功能。

A.3.7.2　安全存取模块

读写器中的安全存取模块包括：随机数发生器、存储器、对称算法处理单元和数据编/解码单元。

随机数发生器用于产生在密钥分散和流加密过程中使用的随机数；存储器用于保存在加密过程中使用的过程密钥、随机数、数据流等；对称算法处理单元用于产生在流加密过程中所要使用的密钥；数据编码单元用于产生对二进制位流进行编码后供射频模块调制发送的数字基带；数据解码单元用于产生对射频模块解调后的数字基带进行解码后供流加密运算的二进制位流。

A.3.7.3　访问流程

读写器对电子标签的访问流程如图 A.4 所示。

A.4　电子标签与读写器通信安全技术

A.4.1　电子标签与读写器通信安全需求

电子标签与读写器通信主要面对安全威胁有：对标签、读写器的非法访问、伪造、跟踪、窃听、数据篡改等，其安全需求有：电子标签与读写器之间的双向身份鉴别、电子标签与读写器之间数据双向传输加密、数据传输安全鉴别等。

A.4.2　电子标签与读写器之间的双向身份鉴别

读写器与标签间的双向身份鉴别采用对称密码算法 SM7 加密的三重身份鉴别机制，以保证标签与读写器在面临非法访问、伪造、跟踪等安全威胁时，攻击者无法通过身份鉴别，从而保证标签与读写器身份的合法性。

具体密钥设置参见 A.5.2。

A.4.3　电子标签与读写器之间数据双向传输加密

电子标签与读写器之间数据双向传输信息采用对称密码算法 SM1/SM4 进行链路加密，以保证传输信息面临窃听等安全威胁时，攻击者得不到明文数据，从而保证信息传输安全。

具体密钥设置参见 A.5.3。

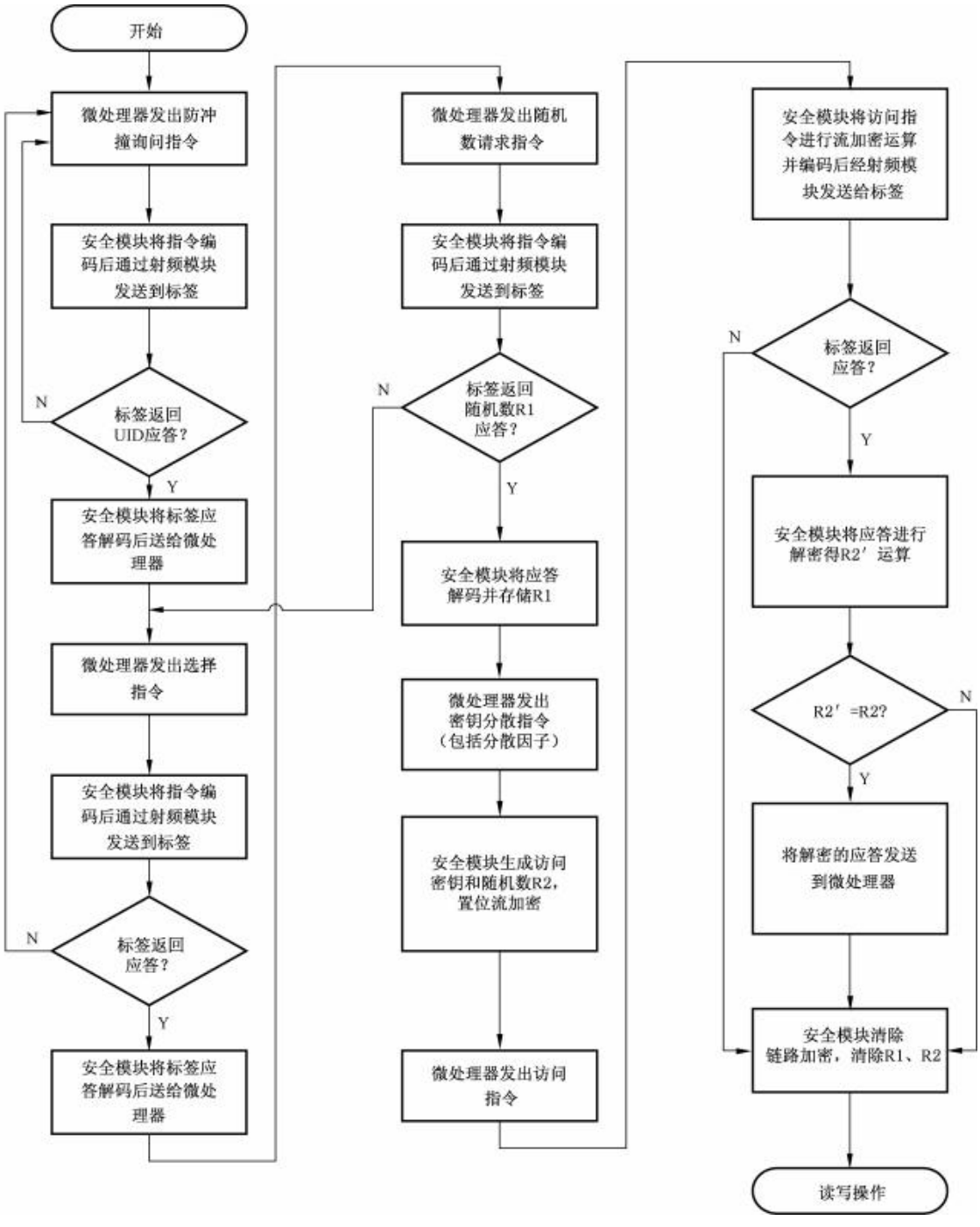

图 A.4　读写器访问电子标签流程图

A.4.4　电子标签与读写器之间数据传输安全鉴别

在电子标签与读写器之间传输的数据后加入代表传输数据特征的数字签名，以保证传输信息在面临数据篡改等安全威胁时，能及时发现数据被篡改，从而保证信息传输安全。

具体密钥设置参见 A.5.4。

A.5 密码算法及密钥管理

A.5.1 密钥管理系统

密钥管理系统的作用是规划、产生、保管、分散、传递、管理以及销毁应用系统的密钥，保证应用系统的安全运行。密钥管理系统采用国家指定的密码算法，原则上采用硬件设备产生各级根密钥，并通过采用国家密码管理主管部门指定的密码算法按应用环节的需要将所需密钥下载或分散至安全存储模块中(SAM 卡)。在各个应用环节，安全存储模块完成密钥分散、密钥认证、传输数据的 MAC 计算以及应用数据的加密等功能。同时，各个应用的安全存储模块所装载的密钥根据应用需要而有所不同，保证各个应用的安全独立性。

A.5.2 对称密码算法 SM7 及密钥管理

该算法用于防伪标签与读写器间数据传输加密和完整性校验，由电子标签芯片和读写器的硬件实现，电子标签内的密钥保存在电子标签芯片中密钥存储区的相应位置；读写器所需的密钥以根密钥的形式保存在安全存取模块(SAM)的安全文件中，在读写器获得电子标签应用标识、UID 等分散因子后，由 SAM 卡将根密钥用标签分散因子进行分散，获得对应的标签密钥。

A.5.3 对称密码算法 SM1/SM4 及密钥管理

A.5.3.1 功能描述

该算法用于防伪标签、读写器和中间件数据存储加密，标签与读写器、读写器与中间件间的传输加密，由读写器及应用系统硬件实现。该算法加解密双方使用同一个密钥，密钥的产生、保管和分发过程必须在受控的安全环境下进行，使用环节的算法和密钥必须保存在通过安全认证的硬件设备(如标签芯片和 SAM 卡)中，加解密运算同样也在此硬件设备中进行，以保证运算过程和中间结果不被泄露，运算结果只能在需要时传输到设备以外。SAM 卡所需的密钥以根密钥的形式保存在 SAM 卡的安全文件中，在读写器获得标签应用标识、UID 等分散因子后，由 SAM 卡将根密钥对标签分散因子进行分散，获得对应的标签密钥保存在 SAM 卡内的临时密钥区，进行后续的加密、解密和鉴别运算。

A.5.3.2 根密钥产生

用于对称密钥体系某一应用的根密钥，必须使用硬件随机数发生器产生。

A.5.3.3 子密钥分散

子密钥分散方法如图 A.5 所示，密钥长度及密钥分散因子长度均为 16 字节。将密钥分散因子作为输入数据，采用国家密码管理主管部门指定的算法进行加密计算，产生的 16 字节的结果作为子密钥。

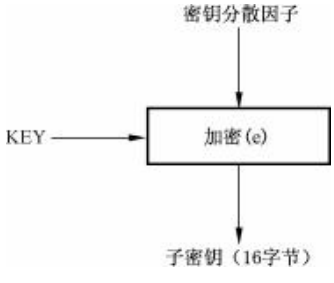

图 A.5 密钥分散计算方法

为保证应用独立和数据安全，对于同一个应用的密钥，针对不同应用范围，采用的密钥值应该不一样。为保证不同标签之间的数据安全，对于同一个应用子密钥，针对不同的标签芯片，采用的密钥值也不一样，对称密钥体系按照不同标签芯片的唯一序列号(UID)生成分散因子，使用密钥分散算法通过应用子密钥对其进行计算获取特定标签芯片使用的密钥值。

A.5.4 非对称密码算法 SM2 及密钥管理

A.5.4.1 功能描述

该算法用于数字签名和完整性校验，由读写器及应用系统硬件实现。非对称算法密钥的产生、保管和分发过程必须在受控的安全环境下进行。使用环节的算法和私钥必须保存在通过安全认证的安全存取模块(USB Key 和 SAM 卡)中，公钥在通讯时可以向外发布。

该系统使用自主建立的 CA 中心并在应用系统和电子标签安全中间件内预置此 CA 中心的根证书，在终端的 SAM 卡和服务器的 USB Key 内保存 CA 中心颁发的通讯加密证书和私钥，并保留临时证书下载区装载通讯对方的数字证书用于通讯加密和签名验证；标签本身不涉及非对称密钥和算法，只用于保存由标签信息写入者对信息的数字签名。

A.5.4.2 密钥对产生

非对称加密所需的密钥只能在通过认证的安全设备(已加载 SM2 算法的 SAM 卡或 USB Key)产生和保存，私有密钥一经产生只能保存在设备中用于运算而不可导出，公开密钥用于加密运算以及导出用于申请数字证书和向外发布。

A.5.4.3 数字证书产生

数字证书就是通讯中标志通讯各方身份信息的一系列数据，它由权威机构发行。最简单的证书包含一个公开密钥、名称以及证书认证中心的数字签名。一般情况下证书中还包括密钥的有效时间、发证机关(证书认证中心)名称、该证书的序列号等信息。

A.5.4.4 数字签名

发送方用自己的私钥对发送信息的摘要进行数字签名。该方式用于标签、读写器及中间件的源鉴别、完整性服务及不可否认服务。

A.5.4.5 数字信封

标签与读写器以及读写器与中间件的数据传输中，采用数字信封技术，即采用非对称算法 SM2 加密对称算法 SM1/SM4 的密钥，采用对称算法 SM1/SM4 加密传输数据。